FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO

REDES DE COMPUTADORES E CIBERSEGURANÇA

PLANO DE RESPOSTAS AOS RISCOS

Pedro Della Rosa Antônio

Pedro Dimitry Zyrianoff

Lucas Kenichi Soares Abe

Eduardo Chen Zou

Projeto Interdisciplinar - Smart Tennis Arena

Tech Tennis: Plano de Resposta aos Riscos

Data: 06/11/2026

Versão: 1.0

1. Introdução

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos e vulnerabilidades identificados no Registro de Riscos do Tech Tennis (Fase 1). O objetivo é reduzir ou eliminar as ameaças aos objetivos do produto, aumentando a maturidade de segurança do sistema antes do uso em treinos reais e em demonstrações públicas e, quando aplicável, aproveitar oportunidades que possam surgir ao longo do roadmap. Este plano deve ser utilizado e atualizado continuamente pela equipe do Tech Tennis, servindo também como evidência das mitigações efetivamente implementadas no código do sistema.

---

2. Tabela de Respostas aos Riscos

Esta tabela serve como o núcleo do plano, detalhando a resposta para cada um dos 20 riscos priorizados no Registro de Riscos (Fase 1). Os campos "Prazo" e "Status" devem ser mantidos atualizados pela equipe conforme as ações forem efetivamente executadas no código e no hardware do sistema.

ID	Descrição do Risco	Nível (Prior.)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável	Prazo	Status
R01	Ausência de autenticação no protocolo de comandos (Serial/Bluetooth): qualquer dispositivo pareado pode controlar servos e laser sem autenticação.	**Alto**	**Mitigar**	1. Definir um token/chave compartilhada enviada em handshake no início da sessão de comandos. 2. Verificar esse token no firmware antes de executar comandos sensíveis (laser, servos). 3. Rejeitar e registrar comandos recebidos sem handshake válido.	Responsável Técnico (Hardware/Embarcados)	03/11/2026	Não Iniciado
R02	Configuração padrão do módulo Bluetooth HC-05 (nome e PIN conhecidos), tornando o pareamento não autorizado plausível.	**Alto**	**Mitigar**	1. Alterar via comandos AT o nome do dispositivo (AT+NAME) para um identificador não óbvio. 2. Alterar o PIN padrão (AT+PSWD) para um valor não trivial, documentado apenas internamente. 3. Validar o novo pareamento com o aplicativo após a alteração.	Responsável Técnico (Hardware/Embarcados)	29/10/2026	Não Iniciado

R03	Ausência de criptografia robusta na comunicação Bluetooth Classic (perfil SPP), permitindo em tese interceptação ou repetição de comandos.	**Médio**	**Aceitar (Ativo)**	1. Documentar formalmente a limitação do perfil SPP do HC-05 como risco aceito nesta fase do protótipo. 2. Reservar item no backlog técnico para avaliação de migração a BLE com pareamento seguro em versão futura do hardware.	Responsável Técnico (Hardware/Embarcados)	Contínuo	Não Iniciado
R04	Ausência de validação e de limitação de taxa (rate limiting) na leitura serial, permitindo envio excessivo de comandos.	**Baixo**	**Mitigar**	1. Implementar intervalo mínimo (debounce) entre comandos aceitos no firmware. 2. Validar explicitamente os caracteres recebidos, descartando qualquer comando fora do conjunto esperado (A, D, W, S, L, E, B, R).	Responsável Técnico (Hardware/Embarcados)	30/10/2026	Não Iniciado
R05	Ausência de mecanismo de parada segura (kill switch): nenhum comando de emergência interrompe servos e laser em caso de falha ou uso indevido (RF22).	**Alto**	**Mitigar**	1. Implementar comando de emergência com prioridade máxima, reconhecido mesmo durante outros processamentos. 2. Desligar o laser e travar os servos na posição atual até reinício explícito do sistema. 3. Testar o comando de emergência em todos os níveis de dificuldade antes da Fase 2.	Responsável Técnico (Hardware/Embarcados)	03/11/2026	Não Iniciado
R06	Ausência de logs e auditoria de comandos, dificultando a identificação de uso indevido ou falhas (RF23).	**Médio**	**Mitigar**	1. Registrar no firmware (via Serial) cada comando recebido, horário relativo e resultado da execução. 2. Avaliar o envio desses registros à API/backend para consolidação centralizada de logs.	Responsável Técnico (Hardware/Embarcados)	05/11/2026	Não Iniciado
R07	Segurança física do laser apontador: se controlado indevidamente, pode ser direcionado a uma posição que represente risco ocular, especialmente a público infantil.	**Médio**	**Mitigar**	1. Limitar por software a faixa de ângulos permitida dos servos a uma zona segura pré-definida. 2. Avaliar e documentar a classe de segurança ocular do módulo laser KY-008 utilizado. 3. Adicionar proteção física (carcaça/anteparo) ao redor do conjunto laser + servos.	Responsável Técnico (Hardware/Embarcados)	03/11/2026	Não Iniciado
R08	Riscos antecipados da futura API/Dashboard: ausência prevista de HTTPS/TLS, exposição de segredos e falta de controle de acesso por perfil.	**Alto**	**Mitigar**	1. Definir HTTPS obrigatório (sem fallback para HTTP) antes do desenvolvimento do dashboard. 2. Implementar gestão de segredos via variáveis de ambiente, nunca hardcoded no código. 3. Aplicar autenticação/autorização por perfil desde a primeira versão da API, evitando reescrita posterior.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado
R09	Proteção de dados de menores (LGPD): ainda não há definição de quais dados são coletados nem como são protegidos.	**Alto**	**Mitigar**	1. Mapear quais dados pessoais são efetivamente coletados (hoje: autenticação Firebase e histórico de partidas). 2. Aplicar minimização, coletando apenas o estritamente necessário ao treino gamificado. 3. Avaliar mecanismo de consentimento adequado para uso por menores.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado

R10	Dependência de fornecimento e concentração de responsabilidade técnica no hardware em um único integrante.	**Baixo**	**Mitigar**	1. Documentar o funcionamento do firmware e da integração de hardware em guia técnico acessível à equipe. 2. Manter o modo de operação via Serial/USB como contingência — já funcional hoje.	Responsável Técnico (Hardware/Embarcados)	03/11/2026	Em Andamento
R11	Falha ou desconexão de câmera da visão computacional durante o uso, interrompendo a detecção real de acertos (há fallback por temporizador).	**Médio**	**Mitigar**	1. Adicionar no aplicativo/dashboard indicador visível de "modo fallback (temporizador)" quando a visão estiver inativa. 2. Implementar tentativa de reconexão automática da câmera em intervalos regulares.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado
R12	Bloqueio da porta do servidor Flask pelo firewall (perfil de rede "Pública"), impedindo o app de alcançar a API sem alerta claro ao operador.	**Alto**	**Mitigar**	1. Criar checklist pré-evento: liberar a porta do servidor no firewall ou alterar o perfil de rede para "Privada". 2. Implementar verificação de conectividade inicial no aplicativo, com mensagem de erro explícita em caso de falha.	Equipe de Desenvolvimento (App Android, Dashboard, API)	03/11/2026	Não Iniciado
R13	Indisponibilidade da porta serial por conflito de software, fazendo o backend operar em modo simulado sem isso ficar evidente ao operador.	**Alto**	**Mitigar**	1. Reforçar na interface do app/dashboard a indicação explícita do estado do Arduino ("conectado" vs. "simulado"). 2. Incluir no checklist pré-evento o fechamento de programas que possam ocupar a porta COM antes de iniciar o backend.	Equipe de Desenvolvimento (App Android, Dashboard, API)	03/11/2026	Em Andamento
R14	Alimentação elétrica insuficiente pela porta USB quando servos e laser operam simultaneamente, causando movimentos imprecisos.	**Médio**	**Mitigar**	1. Adquirir fonte externa dedicada de 5V para os servomotores. 2. Isolar essa alimentação da porta USB do notebook, mantendo terra comum ao Arduino. 3. Testar os níveis Médio e Difícil (movimento contínuo) após a mudança.	Responsável Técnico (Hardware/Embarcados)	31/10/2026	Não Iniciado
R15	Ponto único de falha operacional: todo o sistema depende de um único notebook como servidor, ponte serial e host da visão computacional.	**Médio**	**Mitigar**	1. Desativar atualizações automáticas do sistema operacional no notebook usado em eventos. 2. Preparar e manter um notebook reserva pré-configurado como contingência. 3. Documentar o procedimento de reinício rápido do servidor e da ponte serial.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado
R16	Comunicação app ↔ API em texto puro (HTTP, sem TLS): comandos e pontuação trafegam sem criptografia na rede Wi-Fi local.	**Alto**	**Mitigar**	1. Avaliar HTTPS com certificado autoassinado fixado (pinned) no aplicativo para a rede local. 2. Priorizar essa mudança antes de qualquer exposição do servidor além da rede local controlada.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado
R17	Endereço do servidor configurável na tela de conexão do app, sem validação de formato nem verificação da identidade do servidor.	**Baixo**	**Mitigar**	1. Validar o formato do endereço informado na tela de conexão. 2. Exibir a identificação retornada pelo servidor (nome/versão) antes de confirmar a conexão.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado

R18	Variação das condições de iluminação do ambiente, reduzindo a taxa de detecção da bola ou gerando falsos positivos na visão computacional.	**Alto**	**Mitigar**	1. Implementar recalibração rápida dos parâmetros de cor (HSV) no início de cada sessão. 2. Avaliar controle manual de exposição da câmera para reduzir a dependência da luz ambiente.	Equipe de Desenvolvimento (App Android, Dashboard, API)	05/11/2026	Não Iniciado
R19	Configuração incorreta das regras de segurança do Cloud Firestore, podendo permitir leitura/escrita indevida do histórico de outro usuário.	**Alto**	**Mitigar**	1. Revisar e testar explicitamente as regras do Firestore, restringindo acesso ao próprio usuário autenticado. 2. Incluir esse teste no processo de validação antes de cada fase do roadmap.	Equipe de Desenvolvimento (App Android, Dashboard, API)	03/11/2026	Não Iniciado
R20	A suíte de testes automatizados de integração aciona comandos reais no Arduino, podendo causar movimentação inesperada dos atuadores.	**Baixo**	**Prevenir (Evitar)**	1. Manter a prática já adotada de nunca acionar o laser nesses testes automatizados. 2. Documentar claramente esse comportamento no repositório (README de testes). 3. Exigir confirmação explícita antes de rodar a suíte contra hardware real.	Equipe de Desenvolvimento (App Android, Dashboard, API)	29/10/2026	Em Andamento

3. Detalhamento das Estratégias de Resposta

- Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** mudar o plano do produto para eliminar a ameaça por completo, deixando de realizar a atividade que contém o risco.

  Exemplo no Tech Tennis: nunca acionar o laser durante a suíte de testes automatizados de integração (R20), eliminando esse vetor de risco em vez de apenas reduzi-lo.

- **Transferir:** repassar o impacto negativo do risco (e a responsabilidade pela resposta) a um terceiro, sem eliminá-lo.

  Exemplo no Tech Tennis: ao contratar hospedagem em nuvem para o dashboard em uma fase futura, optar por um provedor com SLA contratual de disponibilidade, transferindo parte do risco de indisponibilidade.

- **Mitigar:** reduzir a probabilidade de ocorrência do risco e/ou seu impacto a um nível aceitável, a estratégia predominante neste plano.

  Exemplo no Tech Tennis: implementar o comando de parada segura (kill switch) no firmware para reduzir o impacto de um comando indevido sobre o laser e os servos (R05).

- **Aceitar:** nenhuma ação proativa é tomada para alterar o plano do produto.

  Aceitação Ativa: reservar uma contingência (tempo, backlog) para lidar com o risco caso ele se materialize, como no caso da limitação de criptografia do Bluetooth Classic do HC-05 (R03), aceita nesta fase do protótipo com um item reservado no backlog técnico.

Aceitação Passiva: não fazer nada e lidar com as consequências caso o risco se materialize, reservada a riscos de prioridade muito baixa, que não é o caso de nenhum item do Registro de Riscos atual do Tech Tennis.

- Estratégias de Oportunidades (Riscos Positivos)

O Registro de Riscos do Tech Tennis é hoje composto majoritariamente por ameaças (riscos negativos). As estratégias abaixo ficam registradas como referência para a equipe, a serem aplicadas caso oportunidades sejam identificadas em fases futuras do roadmap.

- **Explorar:** tomar ações para garantir que a oportunidade se concretize.

  Exemplo no Tech Tennis: dedicar tempo da equipe para validar imediatamente, com usuários reais, se o modo de fallback por temporizador da visão computacional (R11) pode se tornar um diferencial de robustez do produto.

- **Melhorar (ou Realçar):** aumentar a probabilidade de ocorrência da oportunidade e/ou seu impacto positivo.

  Exemplo no Tech Tennis: investir em capacitação da equipe em segurança de aplicações Android e Firebase, aumentando a qualidade das mitigações implementadas nas próximas fases.

- **Compartilhar:** alocar a responsabilidade da oportunidade a um terceiro mais apto a aproveitá-la em benefício do produto.

  Exemplo no Tech Tennis: buscar, em uma fase futura, contato com fabricantes de máquinas lançadoras de bola para uma eventual integração oficial e documentada.

- **Aceitar:** não buscar ativamente a oportunidade, mas aproveitá-la caso aconteça.

  Exemplo no Tech Tennis: aproveitar, caso surja, uma redução de custo em módulos HC-05 de fornecedores, sem negociar ativamente por isso agora.

---

4. Monitoramento e Revisão

Este plano será revisado semanalmente nas reuniões de status da equipe do Tech Tennis, com atenção especial nas semanas que antecedem a entrega de referência da Fase 2. O campo "Status" será atualizado para refletir o progresso das ações planejadas (Não Iniciado, Em Andamento, Concluído, Cancelado). Novos riscos podem ser adicionados e riscos existentes podem ser reavaliados conforme o planejamento do produto avança, este documento é a continuação direta do Registro de Riscos e Vulnerabilidades apresentado na Fase 1 e deve ser atualizado em conjunto com as evidências de código que comprovem as mitigações efetivamente implementadas.